

Industrial Security (Bachelor)

Solution Sheet – Section 09 Standards, Compliance, Governance

Exercise 9.1 – Control Mapping (sample rows)

800-53		62443-3-3 SR	CSF	Feas.	Justification
AC-2	Account mgmt	SR 1.1 / 1.2	PR.AC-1	Mod	Some PLCs lack RBAC
AU-2	Audit events	SR 2.8	DE.CM-1	Hard	Many PLCs lack sys-log
SC-7	Boundary protection	SR 5.1	PR.AC-5	Easy	Industrial firewalls available
CM-2	Baseline cfg	SR 7.6	PR.IP-1	Mod	Engineering project as baseline
IR-4	Incident handling	SR 5.4	RS.AN-1	Hard	OT IR maturity uneven

Exercise 9.2 – SL-T Assignment (sample)

Zone	SL-T	Justification	
Enterprise IT	1	Hacktivists / opportunists; loss has indirect impact	
iDMZ	2	Internet-facing surface, simple resourced attackers	SL-T 4
SCADA / L3	3	Sophisticated, targeted attackers; loss disrupts plant	
Control / L2	3	Same as L3, plus direct safety implications	
Field / L0–1	2	Physically constrained, but consequence is high (nation-state resistance) is normally disproportionate for a regional water utility.	

Exercise 9.3 – Gap Analysis (mark scheme)

Award marks for correctly identifying KRITIS thresholds, NIS2 essential-entity status, B3S sector standard; for credible compliance assessment of asset inventory, segmentation, incident reporting, AV/IR; for realistic improvement costs (EUR ranges, FTE estimates).

Exercise 9.4 – Programme Sketch (sample)

RACI: CISO accountable; OT Security Lead responsible; Plant Manager consulted; CFO informed.

Year 1 priorities: complete asset inventory; segment IT↔OT with iDMZ; immutable backups; vendor remote-access broker; OT IDS; tabletop exercise.

KPIs: % assets in CMDB with firmware version; mean time to detect (MTTD) on OT alerts; % critical CVEs mitigated within SLA.